

DeaIFlow 身份、安全与合规控制

企业知识库文档 | 仅用于测试

文档状态	现行
生效日期	2026-07-01
产品版本	4.2

本资料为虚构企业知识，仅用于检索、能力判断和方案生成测试。

源文件：02-identity-security-compliance.md

身份认证与账号生命周期

Enterprise 和 Dedicated 标准支持 SAML 2.0 与 OpenID Connect

单点登录，可连接一个主身份提供商和一个灾备身份提供商。Business 仅标准支持 OpenID Connect，不包含 SAML。SAML 签名证书轮换允许新旧证书并行七天，Enterprise 每六小时刷新一次身份提供商元数据，Dedicated 可配置为每小时刷新。

所有套餐都支持基于 TOTP 的多因素认证。强制使用硬件安全密钥的 WebAuthn 策略仅在 Enterprise 和 Dedicated 提供。紧急管理员账号不参与普通单点登录，但必须启用多因素认证，其使用会触发高风险审计事件。平台不支持通过短信作为唯一的管理人员第二因素。

Enterprise 和 Dedicated 支持 SCIM 2.0 用户与群组同步。目录增量同步每三十分钟执行一次；身份提供商发出停用事件后，平台通常在十五分钟内阻止新会话，并在六十分钟内撤销存量访问令牌。若客户要求五分钟内完成所有账号和令牌失效，标准服务不能保证，需要评估专用事件通道。

角色模型包含管理员、销售、售前和只读审计员。Enterprise 可创建最多二十个自定义角色，Dedicated 可创建最多五十个；Business 只能使用预置角色。字段级权限只覆盖客户信息、报价和提案正文，不覆盖任意数据库列。权限变更在五分钟内生效，并保留修改前后值。

加密与密钥管理

所有外部连接使用 TLS 1.2 或 TLS 1.3，TLS 1.0 和 1.1 已禁用。静态数据、对象存储文件和备份使用 AES-256 加密。平台默认使用由 DealFlow 托管的云密钥，密钥材料存储在经认证的硬件安全模块中，生产与非生产环境使用不同密钥域。

Dedicated 可选购客户专属密钥，支持每九十天自动轮换，也允许客户发起立即轮换。该选项为专属租户使用独立密钥，不等同于客户自行保管根密钥。客户管理密钥和外部 KMS 直连目前属于受控定制，必须通过架构、安全和恢复能力评审；Business 与 Enterprise 标准套餐不提供 BYOK。

密钥吊销会导致受保护数据不可读取，因此平台要求双人审批并保留恢复窗口。备份副本随所属密钥域加密，不能因为删除主数据就绕过既定备份保留期。日志中不会记录完整令牌、密码或密钥材料。

审计、日志与合规

认证日志记录登录成功、失败、MFA 挑战、令牌撤销和紧急账号使用，所有套餐默认保留一百八十天。业务审计日志记录知识文档上传、版本替换、需求结论覆盖、提案审批和导出。Business 保留一百八十天，Enterprise 保留三百六十五天，Dedicated 保留七百三十天。应用运行日志用于故障排查，默认只保留三十天，不应与业务审计日志混淆。

Enterprise 与 Dedicated 可将认证和业务审计事件通过 HTTPS 或 Syslog over TLS 导出到客户 SIEM，交付延迟目标为五分钟以内。Business 可以按月导出 CSV，但不提供实时推送。审计记录使用追加写入存储，租户管理员不能修改原记录；更正操作会产生一条新记录。

DealFlow SaaS 范围已通过 ISO/IEC 27001:2022 认证并完成年度 SOC 2 Type II 审计。认证覆盖平台研发、云端运行和客户支持流程，不覆盖客户自行开发的集成代码。中国大陆 Dedicated 部署可以配合等保三级测评，但“可配合测评”不代表每个客户环境自动取得证书，测评、整改和第三方费用需在项目中单独约定。

平台提供数据处理协议和子处理者清单，支持 GDPR 数据主体请求协作。客户仍是其业务数据的数据控制者，必须确保上传 RFP、简历或联系方式具有合法依据。PCI DSS、HIPAA 和国家秘密信息处理不在标准合规范围内；涉及这些场景必须在上传数据前完成专项评估。

漏洞管理与安全事件

互联网暴露资产每周执行自动漏洞扫描，生产依赖组件持续进行软件成分分析。严重等级采用 CVSS 与实际可利用性共同判断：确认可利用的严重漏洞目标在七十二小时内缓解，高危漏洞目标在十五天内处理，中危漏洞目标在六十天内处理。无法立即升级时，可以先采用网络隔离、规则拦截或关闭受影响功能，但必须保留后续修复计划。

独立渗透测试每年至少进行一次，范围覆盖身份、租户隔离、关键 API 和管理界面。客户可以在签署保密协议后获取执行摘要，不提供可能暴露其他租户或防御细节的完整攻击脚本。客户自行测试前必须提前申请窗口，禁止拒绝服务、社会工程和访问其他租户数据。

确认影响客户数据机密性、完整性或可用性的安全事件后，DealFlow 在不无故延迟的前提下通知受影响客户，合同默认通知目标为二十四小时内。初次通知可以不包含尚未确认的根因，但会说明已知影响、临时措施和后续更新渠道。最终报告会区分平台责任、客户配置和第三方因素。

隐私请求与数据最小化

客户可以通过管理界面检索、导出或删除其控制的联系人数据。DealFlow 在收到有效工单后协助处理访问、更正和删除请求，标准目标为十个工作日内完成平台侧操作。若数据仍位于不可变备份，在线系统会先删除，备份副本在保留期结束后过期，并禁止为普通业务目的恢复。

生产支持默认不查看客户正文。确需排障时，客户授权联系人必须批准限时访问，系统记录访问人员、原因、范围和结束时间。支持人员只能看到解决问题所需的最少信息；导出的诊断包会移除令牌、密码和密钥材料。